



RELATÓRIO ANALÍTICO

GRAU DE SIGILO RESERVADO

ACADI-TI

RELATORIO N° 001/2024 – Cti-grupo6

1. DATA	05 de Maio de 2024
2. ASSUNTO	Incidente contra Kaseya
3. ORIGEM	John Doe - Serviços Financeiros
4. REFERÊNCIA	RFI - 2023-9012001
5. ANALISTAS	Grupo 6 MARCO AURELIO DA SILVA DA CRUZ BRUNA MEDEIROS EULER MATSUOKA GABRIEL VIEIRA THIAGO DUTRA JAIRO MAZINI ROGER WILLIAN LEANDRO DIONÍZIO RAMOS HÉLIO VIEIRA DE SOUSA JUNIOR

1. FATOS CONHECIDOS:

A Kaseya, foi vítima de uma possível campanha de ransomware de um adversário conhecido como REvil (aka Sodinokibi, Sodin), ocorrido em meados de 2021.

2. REQUISITOS DE INTELIGÊNCIA:

- Identificar adversário envolvido no ataque contra a Kaseya;
- Avaliar o suposto incidente ocorrido em meados de 2021, e se de fato aconteceu; e

- Fornecer informações adicionais que possam ajudar o time de defesa a identificar os TTPs utilizados por este adversário, bem como a vulnerabilidade explorada.

3. SUMÁRIO EXECUTIVO

O ataque começou em 2 de julho de 2021 quando os invasores exploraram uma vulnerabilidade 0-day no Kaseya VSA, um software usado por provedores de serviços gerenciados (MSP ou Managed Service Provider) para monitorar remotamente sistemas de TI, desta forma, atingiram os clientes desses MSPs.

Uma das vulnerabilidades que permitiu a disseminação do ransomware através de atualização falsa do software Kaseya VSA é a CVE-2021-30116 que basicamente permite contornar a autenticação e executar comandos arbitrários. Como resultado, os invasores conseguiram explorar as funcionalidades do Kaseya VSA para implantar o malware nos endpoints administrados pelo produto.

Estima-se que 1500 pequenas e médias empresas tenham sido afetadas pelo ataque através de seus MSPs. Além disso, o grupo criminoso REvil afirmou que mais de um milhão de sistemas foram infectados. Os invasores exigiram um resgate de US\$ 70 milhões.

O ataque teve como impacto significativo e destacou a importância de medidas preventivas robustas para proteção de ameaças cibernéticas.

4. PONTOS PRINCIPAIS

- O REvil (Ransomware Evil; também conhecido como Sodinokibi) era uma operação de ransomware como serviço (RaaS) privada com base na Rússia ou falante de russo.
- Por meio de exploração de vulnerabilidades, o grupo Sodinokibi atingiu diversas empresas clientes da Kaseya.
- O ataque em cadeia (supply-chain attack) foi distribuído nos clientes da Kaseya por meio de distribuição de atualizações falsas
- O caso Kaseya fornece insights valiosos sobre táticas de ataque supply-chain e exploração de vulnerabilidades

5. AVALIAÇÃO

O ataque começou quando os invasores exploraram uma vulnerabilidade de dia zero no Kaseya VSA, um software usado por provedores de serviços gerenciados (MSPs) para monitorar remotamente sistemas de TI, resultando nas seguintes afirmações:

- A vulnerabilidade de dia zero explorada pelos invasores permitiu que eles contornassem a autenticação e ganhassem acesso ao Kaseya VSA. Essa vulnerabilidade não tinha correção disponível no momento do ataque, o que tornou os sistemas vulneráveis.
- Os invasores direcionaram os provedores de serviços gerenciados (MSPs) que usavam o Kaseya VSA. Ao comprometer esses MSPs, eles obtiveram acesso aos sistemas dos clientes desses provedores.
- O ransomware foi distribuído por meio de uma atualização de software falsa. Os invasores conseguiram inserir o malware no Kaseya VSA, que, por sua vez, distribuiu o ransomware para os sistemas dos clientes. Isso resultou em uma ampla infecção.
- O ataque à Kaseya destacou a importância da segurança cibernética, da aplicação de patches e da colaboração entre fornecedores de software e empresas de segurança. Também ressaltou a necessidade de backups regulares e de planos de resposta a incidentes.

A vulnerabilidade no caso Kaseya foi detectada e relatada pelo Instituto Holandês para Divulgação de Vulnerabilidades (DIVD). Segundo nossa investigação, o grupo Kaseya estava ciente das vulnerabilidades em seu software antes do ataque. A empresa tomou medidas para corrigir essas falhas nas versões 9.5.5 e 9.5.6 do Kaseya VSA. No entanto, o ataque ocorreu antes que todas as organizações pudessem aplicar essas correções, resultando em um impacto significativo. A rápida detecção e correção de vulnerabilidades é crucial para prevenir ataques cibernéticos em larga escala como o que ocorreu no caso Kaseya.

6. PRINCIPAIS LACUNAS DE INTELIGÊNCIA

- Os invasores exploraram uma vulnerabilidade de dia zero no software Kaseya VSA (CVE-2021-30116). Essa vulnerabilidade permitiu que eles contornassem os controles de autenticação e ganhassem acesso aos servidores VSA da

Internet, apesar de todas essas informações, não sabemos ao certo como foi possível identificá-las.

- Estima-se que mais de mil empresas foram atingidas pelo ataque em todo o globo. Essas empresas estavam direta ou indiretamente ligadas à Kaseya, porém não temos informação do real impacto do ataque.
- A escolha da Kaseya como alvo também parece ter sido estratégica. Invadindo um fornecedor de tecnologia para provedores de serviços gerenciados, como o Kaseya, o software malicioso teria um alto nível de confiança para penetrar nos dispositivos do cliente, o que sugere um nível de planejamento e conhecimento dos sistemas da Kaseya por parte dos invasores. Embora não temos informações que provem este ponto.

Ataque de ransomware Kaseya VSA de um “trusted third party” não identificado, mais tarde descoberto ser o FBI que reteve a chave por três semanas e estava ajudando as vítimas a restaurar seus arquivos. A chave foi retida para evitar avisar o REvil sobre um esforço do FBI para derrubar seus servidores, o que acabou se revelando desnecessário depois que os hackers ficaram offline sem intervenção.

A operação bem-sucedida baseou-se na extensa coleta de informações sobre ameaças cibernéticas pelo FBI, AFP e seus parceiros. O chefe de estratégia de segurança cibernética da VMWare disse: “O FBI, em conjunto com o Comando Cibernético, o Serviço Secreto e países com ideias semelhantes, realmente se envolveu em ações perturbadoras significativas contra esses grupos”. Através desta recolha de informações, as autoridades policiais identificaram a infraestrutura e os principais indivíduos por detrás dos ataques de ransomware REvil.

Em setembro de 2021, a empresa romena de segurança cibernética Bitdefender publicou um utilitário de descryptografia universal gratuito para ajudar as vítimas do ransomware REvil/Sodinokibi a recuperar seus arquivos criptografados, caso tenham sido criptografados antes de **13 de julho de 2021**.

A operação também envolveu esforços coordenados para interromper as comunicações da gangue, confiscar seus servidores e prender indivíduos associados ao grupo. Como resultado desta operação bem-sucedida, as operações de ransomware do REvil foram interrompidas e vários indivíduos associados ao grupo foram presos. Este é um exemplo resumido de como a inteligência contra ameaças cibernéticas pode ser usada para identificar e interromper as operações de grupos de ransomware.

7. Tabela MITRE ATT&CK (baseada na versão v12)

Attribution	Tactics	Techniques	Sub Technique	Procedure	D3FEND
REvil	Defense Evasion, Privilege Escalation	T1134 - Access Token Manipulation	.002 Create Process with Token	REvil can launch an instance of itself with administrative rights using runas.	https://d3fend.mitre.org/offensive-technique/attack/T1134.002/
REvil	Command and Control	T1071 – Application Layer Protocol	.001 Web Protocols	REvil has used HTTP and HTTPS in communication with C2.	https://d3fend.mitre.org/offensive-technique/attack/T1071.001/
REvil	Execution	T1059 - Command and Scripting Interpreter	.005 Visual Basic	REvil has used obfuscated VBA macros for execution.	https://d3fend.mitre.org/offensive-technique/attack/T1059.005/
REvil	Impact	T1486 - Data Encrypted for Impact	No sub-techniques	REvil can encrypt files on victim systems and demands a ransom to decrypt the files.	https://d3fend.mitre.org/offensive-technique/attack/T1486/
REvil	Defense Evasion	T1140 - Deobfuscate/Decode Files or Information	No sub-techniques	REvil can decode encrypted strings to enable execution of commands and payloads.	https://d3fend.mitre.org/offensive-technique/attack/T1140/

8. CRONOGRAMA DE ATIVIDADES

Attribution	Start Date	End Date	Location	Sector	Activity
Kaseya	02/07/2021	02/07/2021	Miami, Flórida, Estados Unidos.	Cybersecurity	Kaseya detecta um possível incidente de segurança envolvendo sua ferramenta de gerenciamento remoto de computadores Kaseya VSA.
Kaseya	03/07/2021	03/07/2021	Miami, Flórida,	Cybersecurity	Kaseya confirma que foi vítima de um ataque

ACADI-TI - Cti-grupo6

			Estados Unidos.		cibernético.
REvil	04/07/2021	04/07/2021	-	-	O grupo REvil assume publicamente autoria e sucesso do ataque.
REvil	05/07/2021	06/07/2021	-	-	O grupo REvil exigiu um resgate de US\$ 70 milhões para liberar os sistemas afetados.
Centro Nacional de Segurança Cibernética do Reino Unido	06/07/2021	06/07/2021	Reino Unido	The National Cyber Security Centre	O Centro Nacional de Segurança Cibernética do Reino Unido confirmou que várias empresas foram afetadas.
DIVD CSIRT	10/07/2021	10/07/2021	Holanda	Cybersecurity	Um relatório indicou que a Kaseya havia sido alertada sobre a falha de segurança antes do ataque.
Kaseya	11/07/2021	11/07/2021	Miami, Flórida, Estados Unidos.	Cybersecurity	A restauração dos serviços SaaS foi concluída.
REvil	13/07/2021	13/07/2021	-	-	Todos os sites do grupo REvil saíram do ar repentinamente.
Kaseya	26/07/2021	26/07/2021	Miami, Flórida, Estados Unidos.	Cybersecurity	Kaseya diz que a ferramenta de descryptografia é "100% eficaz", sem resgate pago

9. INDICATORS OF COMPROMISE (IOC)

9.1 - MALWARE

Attribution	Malicious Tool Name	Hash Type	File Hash	Associated Files Hash	Brief Description	Malware Analysis Report (Hyperlink, or N/A)	First Reported	Last Reported
REvil	agent.crt	MD5	939aae3cc456de8964cb182c75a5f8cc	-	-	Encoded malicious content	-	-
REvil	agent.exe	MD5	561cffbaba71a6e8cc1cdceda990ead4	5162f14d75e96edb914d1756349d6e11583db0b0	VirusTotal - File - d55f983c994caa160ec63a59f6b4250fe67fb3e8c43a388aec60a4a6978e9f1e	Decoded contents of agent.crt	2021-07-01 12:40:29 UTC	2024-04-23 17:30:15 UTC
REvil	mpsvc.dll	MD5	a47cf00aedef769d60d58bfe00c0b5421	656c4d285ea518d90c1b669b79af475db31e30b1	VirusTotal - File - 8dd620d9aeb35960bb766458c8890ede987c33d239cf730f93fe49d90ae759dd	Ransomware Payload	2021-07-02 19:06:53 UTC	2024-04-23 08:25:12 UTC

9.2 – REDE

Attribution	Network Artifact	Details	Intrusion Phase	First Reported	Last Reported
REvil	35.226.94[.]113	ndereço IP foi reportado por tentar acessar servidores com Kaseya VSA	Intrusion	6/07/2021	-
REvil	161.35.239[.]148	ndereço IP foi reportado por tentar acessar	Intrusion	6/07/2021	-

ACADI-TI - Cti-grupo6

		servidores com Kaseya VSA			
REvil	162.253.124[.]162	ndereço IP foi reportado por tentar acessar servidores com Kaseya VSA	Intrusion	6/07/2021	-

9.3 - ARTEFATOS DO SISTEMA

Attribution	Host Artifact	Type	Details	Tactic	First Reported	Last Reported
Revil	cert.exe	Executável	Arquivo legítimo do windows com um string randômico adicionado utilizado para decodificar 2 artefatos maliciosos	Defense Evasion	06/07/2021	-

9.4 - Common Vulnerabilities and Exposures (CVEs)

Attribution	CVE Number	CVSS Score	Patch Available (Y/N)	Other Remediation	Date Reported	Patch Applied (Y/N/UNK/NA)
	CVE-2021-30116	9.8	Y		07/09/2021	UNK
	CVE-2021-30119	5.4	Y		07/09/2021	UNK
	CVE-2021-30120	7.5	Y		07/09/2021	UNK

10. ASSINATURAS

10.1 - Assinatura YARA para detectar artefatos do ataque no sistema:

https://github.com/cado-security/DFIR_Resources_REvil_Kaseya/blob/main/IOCs/Yara.rules

10.2 - Domínios Encontrados:

https://github.com/cado-security/DFIR_Resources_REvil_Kaseya/blob/main/IOCs/Domains.txt

10.3 - Hashes disponíveis:

45aebd60e3c4ed8d3285907f5bf6c71b3b60a9bcb7c34e246c20410cf678fc0c
36a71c6ac77db619e18f701be47d79306459ff1550b0c92da47b8c46e2ec0752
7ea501911850a077cf0f9fe6a7518859
e1d689bf92ff338752b8ae5a2e8d75586ad2b67b
e2a24ab94f865caeacdf2c3ad015f31f23008ac6db8312c2cbfb32e4a5466ea2
0299e3c2536543885860c7b61e1efc3f
682389250d914b95d6c23ab29dffee11cb65cae9
df2d6ef0450660aaae62c429610b964949812df2da1c57646fc29aa51c3f031e
835f242dde220cc76ee5544119562268
8118474606a68c03581eef85a05a90275aa1ec24
dc6b0e8c1e9c113f0364e1c8370060dee3fcbe25b667ddeca7623a95cd21411f
849fb558745e4089a8232312594b21d2
1bcf1ae39b898aaa8b6b0207d7e307b234614ff6
d8353cfc5e696d3ae402c7c70565c1e7f31e49bcf74a6e12e5ab044f306b4b20
561cffbaba71a6e8cc1cdceda990ead4
5162f14d75e96edb914d1756349d6e11583db0b0
d55f983c994caa160ec63a59f6b4250fe67fb3e8c43a388aec60a4a6978e9f1e
4a91cb0705539e1d09108c60f991ffcf
7895e4d017c3ed5edb9bf92c156316b4990361eb
d5ce6f36a06b0dc8ce8e7e2c9a53e66094c2adfc93cfac61dd09efe9ac45a75f
7d1807850275485397ce2bb218eff159
45c1b556f5a875b71f2286e1ed4c7bd32e705758
cc0cdc6a3d843e22c98170713abf1d6ae06e8b5e34ed06ac3159adafe85e3bd6
8535397007ecb56d666b666c3592c26d
0912b7cecfbe82d6903a8a0dc421c285480e5caa
aae6e388e774180bc3eb96dad5d5bfefd63d0eb7124d68b6991701936801f1c7
5a97a50e45e64db41049fd88a75f2dd2
20e3a0955baca4dc7f1f36d3b865e632474add77
66490c59cb9630b53fa3fa7125b5c9511afde38edab4459065938c1974229ca8
040818b1b3c9b1bf8245f5bcb4eebbbc
c0f569fc22cb5dd8e02e44f85168b4b72a6669c3
0496ca57e387b10dfdac809de8a4e039f68e8d66535d5d19ec76d39f7d0a4402
be6c46239e9c753de227bf1f3428e271

13d57aba8df4c95185c1a6d2f945d65795ee825b
81d0c71f8b282076cd93fb6bb5bfd3932422d033109e2c92572fc49e4abc2471
a560890b8af60b9824c73be74ef24a46
c2bb3eef783c18d9825134dc8b6e9cc261d4cca7
8e846ed965bbc0270a6f58c5818e039ef2fb78def4d2bf82348ca786ea0cea4f
a47cf00aedef769d60d58bfe00c0b5421
656c4d285ea518d90c1b669b79af475db31e30b1
8dd620d9aeb35960bb766458c8890ede987c33d239cf730f93fe49d90ae759dd
18786bfac1be0ddf23ff94c029ca4d63
3c2b0dcdb2a46fc1ec0a12a54309e35621caa925
1fe9b489c25bb23b04d9996e8107671edee69bd6f6def2fe7ece38a0fb35f98e

10.4 - Registry Keys

HKEY_LOCAL_MACHINE\SOFTWARE\Wow6432Node\BlackLivesMatter

11. FEEDBACK

Endereço de E-mail: Cti-grupo6@acadi.com.br

Caro Cliente,

Agradecemos por dedicar um tempo para fornecer feedback sobre nosso relatório de CTI recentemente publicado. Sua opinião é extremamente valiosa para nós e nos ajudará a melhorar continuamente nossos serviços.

Por favor, sinta-se à vontade para compartilhar suas observações, incluindo se o relatório atendeu aos seus Requisitos de Inteligência, sugestões sobre como poderíamos torná-lo mais prático e quaisquer outras questões relacionadas que gostaria que abordássemos em futuras edições do relatório.

Fontes de dados:	• <u>CNET</u> • <u>BBC News</u> • <u>Welivesecurity</u> • <u>CSO</u> • <u>Picusecurity</u> • <u>DIVD CSIRT</u> • <u>Talos</u> • <u>Huntress</u>
------------------	---

Threat Actor:	• REvil • Conhecido como Sodinokibi
Victim Location:	• Reino Unido, África do Sul, Canadá, Alemanha, Estados Unidos, Colômbia, Suécia, Kenia, Argentina, México, Países Baixos, Indonésia, Japão, Ilhas Maurício, Nova Zelândia, Espanha e Turquia, entre outros
Sectors:	• Governo, Serviços Profissionais, Varejo, Atacado e MSPs
Infrastructure Used	• SQL Injection
Actor Motivation:	• Data Theft, Cyber Crime, Ransomware